

Analisi Statica di un Campione Malevolo

Mascherato da Applicazione di Sistema

Relazione di Laboratorio — Attività di Ethical Hacking e Malware Analysis

Ambiente di lavoro: macchina virtuale FlareVM (ambiente isolato e controllato)

Campione analizzato: notepad-classico.exe

Tipologia di attività: analisi statica di malware a scopo didattico

1. Introduzione

Nell'ambito delle attività didattiche relative alla disciplina della sicurezza informatica, è stata condotta un'esercitazione pratica di malware analysis avente ad oggetto un file eseguibile denominato notepad-classico.exe, reperito all'interno della cartella "Malware" della macchina virtuale FlareVM. FlareVM costituisce una distribuzione Windows specificamente configurata per l'analisi di codice malevolo, dotata di un insieme completo di strumenti di reverse engineering, analisi statica e dinamica, ed è stata impiegata in qualità di ambiente isolato, privo di connessione a reti di produzione, al fine di prevenire qualsiasi rischio di propagazione accidentale del campione in esame.

2. Obiettivi dell'Attività

Coerentemente con quanto stabilito dalla consegna dell'esercizio, l'attività si è posta i seguenti obiettivi specifici:

- Identificare, mediante analisi statica, le librerie (DLL) importate dinamicamente dal campione notepad-classico.exe, fornendo per ciascuna di esse una descrizione tecnica elaborata con il supporto di strumenti di intelligenza artificiale;
- Individuare le sezioni che compongono la struttura del file eseguibile (formato PE — Portable Executable), fornendo per ciascuna una descrizione tecnica delle relative funzioni e proprietà;
- Formulare, quale approfondimento facoltativo, una considerazione conclusiva sulla natura e sulla pericolosità del campione, sulla base delle evidenze raccolte ed elaborate.

3. Metodologia e Ambiente di Analisi

La metodologia adottata ha seguito un approccio incrementale, tipico delle attività di triage iniziale di un campione sospetto, articolato secondo le seguenti fasi:

1. Isolamento dell'ambiente di lavoro, mediante l'impiego di una macchina virtuale dedicata (FlareVM) priva di accesso a reti locali o aziendali;
2. Raccolta di metadati e valori di hash del file, propedeutica a qualunque ulteriore fase di indagine;
3. Analisi statica automatizzata tramite lo strumento Detect It Easy, finalizzata all'identificazione del tipo di file, del compilatore e di eventuali tecniche di offuscamento;
4. Verifica di reputazione tramite la piattaforma collaborativa VirusTotal, per la raccolta di riscontri incrociati da parte di molteplici motori antivirus e regole di rilevamento comportamentale (YARA);
5. Analisi statica approfondita tramite lo strumento PEStudio, per l'esame dettagliato delle librerie importate e delle sezioni del file;
6. Interpretazione e sintesi dei risultati con il supporto di un modello linguistico di intelligenza artificiale, impiegato quale strumento di ausilio alla comprensione tecnica dei dati raccolti.

Si evidenzia come, coerentemente con le indicazioni della consegna, il campione non sia mai stato eseguito in nessuna fase dell'attività: l'intera analisi ha carattere esclusivamente statico, ovvero condotta sul file "a riposo", senza attivazione del codice in esso contenuto.

A ulteriore garanzia della sicurezza dell'ambiente di laboratorio, si segnala come la macchina virtuale fosse dotata di uno script di segmentazione di rete (start_router.sh), riportato in Figura 1, predisposto per impedire, tramite regole del firewall iptables, qualsiasi comunicazione in uscita verso intervalli di indirizzi IP privati (192.168.0.0/16, 172.16.0.0/12, 10.0.0.0/8), con conseguente registrazione (logging) di ogni tentativo di connessione verso tali reti. Tale accorgimento, sebbene non direttamente richiesto dalla consegna, rappresenta una buona prassi metodologica nell'analisi di codice potenzialmente malevolo, in quanto riduce ulteriormente la superficie di rischio in caso di esecuzione accidentale del campione.

Figura 1 — Script di isolamento di rete (start_router.sh) impiegato per la segmentazione del laboratorio di analisi, con regole iptables di blocco e registrazione del traffico diretto verso reti private.

4. Fase 1 — Raccolta delle Informazioni Preliminari

Come primo passo dell'indagine, si è proceduto al calcolo dei valori di hash crittografico del campione, operazione indispensabile ai fini dell'identificazione univoca del file e della successiva interrogazione delle banche dati di intelligence sulle minacce.

Tabella 1 — Valori identificativi del campione

Proprietà	Valore
Nome file	notepad-classico.exe
MD5	8a00a5c59ac157754ca575d721bcf960
SHA-1	c31e260630d6553e2000f8e5f8dc270c751780d9
SHA-256	d2e6c9f9273663f3218bcd7cbfb3b6f599fbce7a4ba986f9bbff77e3603988f2
Dimensione	289.280 byte (282,50 KiB)
Percorso completo	C:\Users\FlareVM\Downloads\notepad-classico.exe
Data di modifica	24/07/2025 06:26:46
Data di creazione (sistema di analisi)	04/08/2026 05:09:20
Versione file dichiarata	5.1.2600.5512 [xpsp.080413-2105]
Versione prodotto dichiarata	5.1.2600.5512

Figura 2 — Elenco del file oggetto di analisi con relativi valori di hash MD5 e SHA-256, dimensione e marche temporali.

Figura 3 — Finestra delle proprietà estese del file, riportante l'insieme completo dei valori di hash (MD5, SHA-1, CRC32, SHA-256, SHA-384, SHA-512) e i metadati di versione.

Si osserva, quale prima anomalia rilevata, una significativa discrepanza tra la versione dichiarata dal file (5.1.2600.5512), corrispondente storicamente al componente Blocco Note distribuito con Windows XP Service Pack 3, e le marche temporali di modifica e creazione, riconducibili rispettivamente agli anni 2025 e 2026. Tale incongruenza cronologica costituisce un primo indicatore, ancorché non conclusivo, di una possibile alterazione del file originale a fini di occultamento (tecnica nota in letteratura come masquerading, catalogata all'interno del framework MITRE ATT&CK con identificativo T1036).

5. Fase 2 — Analisi Statica Automatizzata (Detect It Easy)

Al fine di ottenere una prima caratterizzazione tecnica del file, si è proceduto all'analisi mediante lo strumento Detect It Easy (DiE), utilizzato per la determinazione del formato, del compilatore e di eventuali tecniche di compressione o offuscamento del codice.

Tabella 2 — Risultati dell'analisi con Detect It Easy

Parametro	Valore rilevato
Tipo di file	PE32
Architettura	I386 (32-bit)
Endianness	Little Endian (LE)
Tipo applicazione	GUI
Sistema operativo dichiarato	Windows 95
Linker	Microsoft Linker (7.10.4035)
Compilatore	Microsoft Visual C/C++ (13.10.4035)
Linguaggio	C
Ambiente di sviluppo	Visual Studio (2003)
Indicatore euristico	(Heur) Packer: Compressed or packed data — rilevato tramite ripetizione dei nomi delle sezioni e pattern "pusha..." in corrispondenza dell'entry point

Figura 4 — Interfaccia dello strumento Detect It Easy, con evidenza dell'indicatore euristico di possibile compressione o offuscamento del codice.

Il riscontro più rilevante emerso in questa fase è rappresentato dall'indicatore euristico relativo alla probabile presenza di dati compressi o offuscati (packed data), motivato dalla ripetizione dei nomi delle sezioni e dalla presenza, in corrispondenza del punto di ingresso del programma, di un pattern di istruzioni assembly (pusha) tipicamente associato a routine di unpacking o stub di decompressione eseguiti in fase di avvio. Tale evidenza risulta coerente con quanto successivamente confermato dall'analisi dell'entropia condotta con PESTudio (cfr. Sezione 9).

6. Fase 3 — Analisi di Intelligence Collettiva (VirusTotal)

Il valore di hash SHA-256 calcolato nella Fase 1 è stato sottoposto alla piattaforma VirusTotal, servizio di threat intelligence che aggrega i responsi di numerosi motori antivirus commerciali, al fine di verificare la reputazione del campione presso la comunità internazionale di sicurezza.

Figura 5 — Sintesi del responso di VirusTotal: 58 motori antivirus su 72 hanno classificato il campione come malevolo, con etichetta di minaccia popolare "trojan.rozena/meterpreter".

Il campione ha ottenuto un tasso di rilevamento pari a 58 rilevamenti su 72 motori antivirus interrogati, valore che rappresenta un indicatore di elevatissima attendibilità circa la natura malevola del file. La piattaforma ha attribuito al campione l'etichetta di minaccia popolare trojan.rozena/meterpreter, riconducendolo alla categoria "trojan" e associandolo alle famiglie Rozena, Meterpreter e Swrort.

Dalla scheda di dettaglio tecnico sono stati inoltre estratti ulteriori identificativi univoci del campione (vhash, authentihash, imphash, rich PE header hash, ssdeep, TLSH), utili ai fini della correlazione con campioni analoghi presenti in altre campagne malevole, nonché la conferma del tipo di file (Win32 EXE) e degli strumenti di compilazione impiegati.

Figura 6 — Scheda dei metadati tecnici estesi del campione su VirusTotal, con hash di similarità (imphash, ssdeep, TLSH) utili alla correlazione con campagne malevole affini.

Di particolare rilievo risulta il contenuto della sezione Community della piattaforma, nella quale un analista terzo ha documentato la corrispondenza del campione con una regola YARA denominata SUSP_ShellCode_Indicator_Nov22_2, appartenente al set di regole Suspicious2 Indicators dello scanner THOR APT sviluppato da Florian Roth, la cui descrizione ufficiale indica la rilevazione di shellcode riconducibile a semplici reverse shell. Tale riscontro conferma la presenza, all'interno del file, di codice binario grezzo predisposto per essere eseguito in memoria, elemento tipico delle tecniche di post-exploitation impiegate dal framework Metasploit (da cui il payload Meterpreter trae origine).

Figura 7 — Commento della community di VirusTotal relativo alla corrispondenza con la regola YARA "SUSP_ShellCode_Indicator_Nov22_2", indicativa della presenza di shellcode riconducibile a reverse shell.

7. Fase 4 — Analisi Statica Approfondita (PEStudio)

Al fine di completare il quadro informativo raccolto, si è proceduto a un'analisi statica di maggior dettaglio mediante lo strumento PEStudio, specificamente concepito per l'esame preliminare di file eseguibili sospetti in ottica di malware assessment.

Figura 8 — Panoramica generale del file in PEStudio: dimensione, entropia complessiva, punto di ingresso, descrizione del file ("Blocco note") e marca temporale del compilatore.

Dall'analisi generale del file sono emersi i seguenti elementi di rilievo:

- Entropia complessiva del file: 6,273 (su una scala massima di 8), valore compatibile con la presenza di dati parzialmente compressi o cifrati;

- Descrizione interna del file: "Blocco note", coerente con il tentativo di mascheramento come applicazione legittima;
- Nome originale del modulo (campo original-file-name): NOTEPAD.EXE, ulteriore conferma dell'intento di impersonare l'applicazione di sistema Blocco Note;
- Manifest applicativo: Microsoft.Windows.Shell.notepad, elemento anch'esso coerente con la strategia di masquerading;
- Marca temporale di compilazione: domenica 13 aprile 2008, ore 18:35:51 UTC — dato palesemente incompatibile con le marche temporali di modifica e creazione del file rilevate nella Fase 1, a ulteriore riprova di una probabile manipolazione dei metadati.

8. Analisi delle Librerie Importate

L'esame della tabella degli import, condotto tramite PESTudio, ha rilevato un totale di 201 funzioni importate, di cui 18 espressamente segnalate dallo strumento come potenzialmente sospette, distribuite su un insieme di 9 librerie (Dynamic Link Library, DLL) di sistema. Le funzioni contrassegnate come sospette sono state analizzate singolarmente, anche con il supporto di un modello di intelligenza artificiale, al fine di comprenderne la finalità tecnica nel contesto specifico del campione in esame.

Figura 9 — Tabella completa degli import del file, con evidenza delle 18 funzioni classificate come potenzialmente sospette e delle rispettive librerie di provenienza.

Tabella 3 — Librerie importate e relativa descrizione funzionale

Libreria	Funzione tipica	Descrizione tecnica (AI-assisted)
ADVAPI32.dll	Registro di sistema e servizi	Libreria avanzata delle API di Windows, deputata alla gestione del registro di sistema, dei servizi e delle politiche di sicurezza. Espone RegCreateKeyW e RegSetValueExW, tipicamente impiegate per la creazione o modifica di chiavi di registro finalizzate all'ottenimento della persistenza a ogni riavvio del sistema.
KERNEL32.dll	Processi, memoria, file system	Libreria fondamentale del sistema operativo. Importa GetCurrentThreadId, GetCurrentProcess, GetCurrentProcessId (identificazione del contesto d'esecuzione, spesso in tecniche anti-debug), FindFirstFileW, WriteFile, DeleteFileW e, soprattutto, MapViewOfFile/UnmapViewOfFile, impiegate per la mappatura di memoria condivisa, tecnica sfruttata per l'iniezione di codice (process injection).
USER32.dll	Interfaccia utente ed eventi	Gestione di finestre, messaggi e GUI. Importa GetForegroundWindow e GetDesktopWindow (identificazione della finestra attiva), SetWinEventHook/UnhookWinEvent (installazione di hook di sistema) e funzioni di gestione degli appunti (OpenClipboard, CloseClipboard, IsClipboardFormatAvailable), potenzialmente riconducibili a finalità di sorveglianza ed esfiltrazione dati.
COMDLG32.dll	Finestre di dialogo comuni	Implementa le finestre di dialogo standard (GetOpenFileNameW, GetSaveFileNameW, FindTextW, ReplaceTextW, ChooseFontW,

Libreria	Funzione tipica	Descrizione tecnica (AI-assisted)
		PrintDlgExW). Coerente con la componente "di facciata" dell'applicazione Blocco Note usata come copertura.
SHELL32.dll	Interazione con la shell	Espone funzionalità di interazione con la shell (icone, drag-and-drop). La funzione DragFinish è coerente con l'interfaccia grafica dell'applicazione di copertura.
KERNEL32.dll (funzioni di persistenza/evasione)	Manipolazione avanzata della memoria	Si segnala in particolare la coppia MapViewOfFile/UnmapViewOfFile, la cui compresenza con l'elevata entropia della sezione .text rafforza l'ipotesi di una routine di decompressione o decifratura del payload eseguita in memoria all'avvio del processo.

Nota metodologica: le librerie COMCTL32.dll e ulteriori DLL di sistema risultano presenti nell'elenco completo degli import (9 librerie totali), pur non essendo state riportate singolarmente in tabella in quanto associate a funzioni standard dell'interfaccia grafica non direttamente classificate come sospette dallo strumento.

Dall'esame combinato delle librerie e delle funzioni importate emerge un quadro coerente con quello di un contagocce (dropper) o di un impianto (implant) di post-exploitation: da un lato, la presenza di funzioni legate alla gestione di finestre di dialogo e all'interfaccia grafica assicura al programma un aspetto verosimile di applicazione legittima; dall'altro, la combinazione di funzioni per la scrittura su registro di sistema, la manipolazione di file e, soprattutto, la mappatura di memoria virtuale, risulta tipica dei meccanismi di persistenza, evasione e iniezione di codice propri dei payload della famiglia Meterpreter.

9. Analisi delle Sezioni del File Eseguibile

L'esame della struttura interna del file, condotto tramite la funzione di analisi delle sezioni di PEStudio, ha permesso di individuare cinque sezioni, di cui una risultante dalla ripetizione anomala del medesimo nome (.text), circostanza di per sé indicativa di una probabile manipolazione della struttura originaria del file mediante strumenti di packing.

Figura 10 — Tabella delle sezioni del file PE, con relativi valori di entropia, dimensioni e caratteristiche di lettura/scrittura/esecuzione; si segnala l'indicatore "self-modifying" associato alla seconda sezione .text.

Tabella 4 — Sezioni del file eseguibile e relativa descrizione tecnica

Sezione	Entropia	Caratteristiche	Descrizione tecnica (AI-assisted)
.text (0)	6,214	Esecuzione	Contiene tradizionalmente il codice macchina eseguibile. Il valore di entropia, superiore a quanto atteso per codice compilato non compresso (5–6), suggerisce offuscamento o compressione parziale.
.data (1)	1,149	Lettura/Scrittura	Destinata alle variabili globali e statiche inizializzate. Il basso valore di entropia è coerente con la natura non compressa di tale sezione.

Sezione	Entropia	Caratteristiche	Descrizione tecnica (AI-assisted)
.rsrc (2)	5,421	Lettura	Sezione delle risorse (icone, stringhe, dialoghi, versione). Il valore, pur non anomalo in assoluto, è significativo e meritevole di approfondimento dinamico.
.text (3, duplicata)	6,428	Lettura/Scrittura/Esecuzione, self-modifying	Sezione di massimo interesse investigativo: la duplicazione del nome standard .text, unita a permessi RWX simultanei e al flag self-modifying, è tipica di routine di unpacking/stub di decifratura che scrivono ed eseguono codice nella stessa area di memoria all'avvio, tecnica diffusa nei packer malevoli e nei payload Metasploit.
.idata (4)	5,439	Lettura	Contiene la Import Address Table, utilizzata per la risoluzione dinamica degli indirizzi delle funzioni importate dalle librerie esterne (cfr. Sezione 8).

L'elemento di maggior rilievo emerso da tale analisi risiede, con evidenza, nella sezione duplicata .text (sezione 3), la cui combinazione di attributi — permessi RWX (lettura, scrittura ed esecuzione) contemporanei e flag di auto-modifica del codice — rappresenta uno degli indicatori tecnici più affidabili per la classificazione di un file come packed o contenente uno stub di caricamento di uno shellcode, in piena coerenza con quanto già riscontrato nella Fase 3 mediante la corrispondenza con la regola YARA relativa ai reverse shell.

10. Considerazioni Finali

L'insieme delle evidenze raccolte nel corso della presente attività di laboratorio converge, in maniera coerente e reciprocamente corroborante, verso l'identificazione univoca del campione notepad-classico.exe quale trojan appartenente alla famiglia Rozena/Meterpreter, dotato di caratteristiche tipiche dei payload generati mediante framework di post-exploitation quali Metasploit.

Si è potuto osservare come il campione impieghi una strategia articolata su tre livelli:

7. Livello di inganno visivo (masquerading): il nome del file, la sua icona, la descrizione interna ("Blocco note") e il nome del modulo originale (NOTEPAD.EXE) sono stati deliberatamente predisposti al fine di far percepire il file come l'applicazione di sistema Blocco Note, sfruttando la fiducia implicita dell'utente verso componenti nativi del sistema operativo;
8. Livello di offuscamento tecnico (packing): l'elevata entropia riscontrata nelle sezioni contenenti codice eseguibile, unitamente alla duplicazione anomala della sezione .text e alla presenza del flag di auto-modifica del codice, indica con elevata probabilità l'impiego di un packer finalizzato a occultare il payload reale agli strumenti di analisi statica tradizionali;
9. Livello funzionale malevolo: le funzioni importate dalle librerie di sistema, in particolare quelle relative alla scrittura sul registro (persistenza) e alla mappatura di memoria virtuale (iniezione di codice), unitamente alla corrispondenza con la regola YARA relativa a shellcode di tipo reverse shell, confermano la presenza di funzionalità di controllo remoto non autorizzato del sistema.

L'esercitazione ha altresì evidenziato l'efficacia di un approccio metodologico incrementale, che combina strumenti di analisi statica automatizzata, piattaforme di threat intelligence collaborativa e strumenti di analisi manuale approfondita, quale prassi consolidata nell'ambito della disciplina della

malware analysis, nonché l'utilità del supporto di sistemi di intelligenza artificiale quale strumento di ausilio all'interpretazione tecnica — e non sostitutivo — del giudizio critico dell'analista.

11. Conclusioni

L'attività di laboratorio condotta ha consentito di raggiungere pienamente gli obiettivi didattici prefissati, dimostrando come l'applicazione rigorosa di una metodologia di analisi statica strutturata sia in grado di rivelare, con un elevato grado di confidenza, la reale natura di un file eseguibile anche in assenza della sua esecuzione, riducendo così al minimo l'esposizione al rischio nel corso del processo di indagine.

Il campione notepad-classico.exe rappresenta un caso paradigmatico ed esemplificativo delle moderne strategie di social engineering tecnico impiegate dal cybercrime, in cui l'inganno visivo si combina con sofisticate tecniche di offuscamento del codice, a conferma di come la sola vigilanza dell'utente finale, per quanto essenziale, non possa costituire l'unica linea di difesa di un'organizzazione. La sicurezza informatica, come emerso anche dall'analisi dei rischi e delle contromisure sviluppata nella presente relazione, deve pertanto essere concepita come un processo continuo e multilivello, fondato sull'integrazione sinergica di misure tecniche (soluzioni EDR, segmentazione di rete, controllo delle applicazioni), misure organizzative (formazione, procedure di incident response) e un costante affinamento delle competenze analitiche del personale addetto alla sicurezza.

L'esperienza maturata nel corso della presente esercitazione costituisce, in tal senso, un contributo formativo di rilievo per lo sviluppo delle competenze professionali richieste nell'ambito della cybersecurity, in piena aderenza ai principi etici e metodologici propri della disciplina dell'ethical hacking.